

Proposal Evaluation Report against Mobile Enterprise Security Checklist



JCF Document Hub

Proposal Evaluation Report against Mobile Enterprise Security Checklist

**Systems Maintenance and Development Department
Information and Communications Technology Division**

Date Prepared: 11 May 2026

Prepared by:

Mr. Shevon Robinson

Senior Software Engineer, Systems Maintenance and Development Department

Project Lead:

Sgt. Dwayne Aitken

Software Engineer, Systems Maintenance and Development Department

Proposal Evaluation Report against Mobile Enterprise Security Checklist

Document Control and Version History

This document is controlled within the Information and Communications Technology Division (ICTD).
Updates to content, structure, or status shall be recorded in the version history table below.

Authors	Date	Comments	Version
Shevon Robinson	11/05/2026	JCF Document Hub Assessment	1.0

Proposal Evaluation Report against Mobile Enterprise Security Checklist

Table of Contents

Factors for the Development of the Application..... 4

 1.1 Authentication & Authorization 4

 1.2 Backend & API Design 4

 1.3 File Storage & Hierarchy 4

 1.4 PDF Processing & Viewing..... 5

 1.5 User Interface & Experience (File-Explorer-like)..... 5

 1.6 Mobile Platform & Framework 5

 1.7 Security Hardening..... 5

 1.8 Offline Capabilities..... 6

 1.9 Performance & Scalability..... 6

 1.10 Administration, Monitoring & DevOps..... 6

 1.11 Legal & Licensing 6

Checklist Report..... 7

Summary 11

 Strengths..... 11

 Critical missing pieces 11

Recommendation 12

 Priority 1 — Critical (block pilot approval)..... 12

 Priority 2 — High (required before Force-wide rollout)..... 12

 Priority 3 — Medium (strengthens the document) 12

Proposal Evaluation Report against Mobile Enterprise Security Checklist

Factors for the Development of the Application

The following is a comprehensive breakdown of all technical, security, UX, and operational factors required to build the mobile application.

1.1 Authentication & Authorization

- Active Directory integration (on-premises LDAP/LDAPS or Azure AD) for credential verification on the server side.
- Secure transmission (TLS 1.2+) of username/password; no plain-text storage.
- Token-based session management (JWT, OAuth2) issued after successful AD authentication.
- Support for AD security groups, mapping group membership to folder/file access privileges (role-based access control).
- Multi-factor authentication readiness (optional but recommended).
- Password policy enforcement, account lockout, and session expiry aligned with AD policies.
- Secure logout, token revocation, and automatic session timeout on the mobile side.

1.2 Backend & API Design

- RESTful (or GraphQL) API for all file operations: browse directory tree, list folder contents, search, download, stream.
- Endpoints for PDF-specific functions: stream/byte-range requests, thumbnail/preview generation.
- Download endpoint with Content-Disposition headers and support for resumable downloads.
- API authentication via bearer tokens, refresh tokens, and scope validation.
- AD binding logic (e.g., LDAP bind, Kerberos, or Microsoft Graph) encapsulated in an authentication service.
- Rate limiting, throttling, and DDoS protection.
- Logging and auditing of every file-access request.

1.3 File Storage & Hierarchy

- Server-side hierarchical folder structure that mirrors a Windows file explorer (drives/shares/folders).
- Storage back-end: local disk, NAS, or cloud (Azure Files, AWS FSx) preserving NTFS-style permissions.
- Metadata ingestion: file name, size, type, modified date, custom properties (author, tags).
- Indexing service for fast file-name and full-text search (inside PDFs).
- Preservation of Windows-like access control lists (ACLs) when mapping AD groups to files/folders.
- Handling of large directory structures (lazy loading, pagination, caching).

Proposal Evaluation Report against Mobile Enterprise Security Checklist

1.4 PDF Processing & Viewing

- In-app PDF rendering engine (e.g., PDF.js for hybrid, Android PdfRenderer, iOS PDFKit).
- Progressive streaming of PDFs via HTTP byte-range requests – no need to download the whole file for viewing.
- Full offline mode: download PDF to device encrypted storage, accessible from a “Downloads” section.
- PDF viewer features: zoom, page navigation, text search, text selection, bookmarks, rotation.
- Optional annotation and form-filling support (if required).
- Secure handling of downloaded files: encryption at rest (AES), sandboxed app storage, no exposure to other apps without user intent.

1.5 User Interface & Experience (File-Explorer-like)

- Tree/breadcrumb navigation mimicking Windows Explorer: back/up, folder drill-down, address bar.
- Two-pane layout (optional on phones, useful on tablets): folder tree + file list.
- List and grid views with file type icons, thumbnails for PDFs.
- Sort by name, date, size, type; filter by file extension.
- Search bar with real-time client-side filtering and server-side full-text search.
- Contextual actions: download, share, properties, rename, delete (if permitted).
- Refresh mechanism (pull-to-refresh), loading indicators, empty states.
- Dark mode, accessibility (screen reader, dynamic text).
- Offline indicator, “Downloaded Files” tab, sync status.
- Smooth performance with virtualized lists for large folders.

1.6 Mobile Platform & Framework

- Target platforms: iOS and Android (or single cross-platform framework: React Native, Flutter, .NET MAUI).
- Background download manager integration, notification of completed downloads.
- Device file permissions: access to local storage only within app sandbox; optional “Save to Files” sharing.
- Lifecycle handling: resume state after app suspend, persist navigation stack.
- Responsive layout for phones and tablets.

1.7 Security Hardening

- All communication over HTTPS with strong cipher suites.
- Certificate pinning to prevent MITM attacks.
- Secure credential/token storage: iOS Keychain, Android Keystore (EncryptedSharedPreferences).
- Encrypted local database for cached metadata.

Proposal Evaluation Report against Mobile Enterprise Security Checklist

- Downloaded PDFs encrypted and non-exportable unless explicitly shared.
- Server-side validation of user permissions on every request (never rely on client-side restrictions).
- Input sanitization against path traversal, SQL/LDAP injection.
- Regular penetration testing and security code reviews.
- Compliance with privacy laws (GDPR, HIPAA if applicable) – data minimization, consent, right-to-deletion.

1.8 Offline Capabilities

- Cache last-browsed directory structure and metadata for offline navigation.
- Dedicated “Downloads” area listing all stored PDFs with local metadata.
- Conflict detection when a server file is updated after download; option to re-download.
- Queue offline actions (e.g., bookmark, annotate) for later sync (if applicable).

1.9 Performance & Scalability

- API pagination (limit/offset or cursor) for directory listing.
- Image/thumbnail caching (on device and CDN for server).
- PDF streaming with adaptive quality; lazy page rendering.
- Server-side caching of directory listings and AD group membership (with TTL).
- Load testing with concurrent AD authentications and large file sets.
- Efficient full-text search index (Elasticsearch, Azure Cognitive Search) for PDF content.

1.10 Administration, Monitoring & DevOps

- Admin dashboard for configuration (AD connection string, allowed domains, API keys) – not user management, as that stays in AD.
- Audit logs: who accessed/downloaded which file, timestamp, IP, device info.
- Application performance monitoring (APM), crash reporting (Firebase Crashlytics, Sentry).
- CI/CD pipeline for app and backend, automated testing (unit, integration, UI).
- Beta distribution (TestFlight, Google Play Internal Testing) and staged rollouts.
- API versioning and backward compatibility strategy.

1.11 Legal & Licensing

- PDF rendering library licenses (e.g., PDF.js Apache 2.0, commercial if using PSPDFKit).
- Third-party component attributions.
- Terms of Service, Privacy Policy, End-User License Agreement (EULA).
- Data processing agreement if hosted on behalf of an organization.

Proposal Evaluation Report against Mobile Enterprise Security Checklist**Checklist Report**

Section	Factor	Coverage	Gap
Authentication & authorization	AD credential verification (LDAP/LDAPS or Azure AD)	Partial	MSAL / OAuth 2.0 is specified for the client; no description of server-side AD verification logic or LDAPS binding.
Authentication & authorization	Secure credential transmission (TLS, no plain-text)	Partial	MSAL is cited which implies TLS, but TLS version, certificate pinning, and in-transit encryption are never stated explicitly.
Authentication & authorization	Token-based session management (JWT/OAuth)	Full	OAuth 2.0 / OpenID Connect via MSAL is clearly specified. Tokens are not stored by the app.
Authentication & authorization	AD group → file/folder access rights mapping	No coverage	No mention anywhere of different officers having different document access. Access appears flat (all or nothing).
Authentication & authorization	Session timeout, token refresh, secure logout	Partial	Idle re-authentication is mentioned for lost/stolen devices, but session TTL, token refresh flow, and logout behaviour are not specified.
Authentication & authorization	Multi-factor authentication (MFA)	Full	MFA is explicitly addressed via Microsoft 365 Conditional Access — no gaps.
Backend / API	RESTful/GraphQL API design for file operations	No coverage	No API endpoints, methods, payloads, or response schemas are described anywhere in the document.
Backend / API	PDF streaming endpoints (byte-range support)	No coverage	Not addressed. The document says PDFs open inside the app but says nothing about server-side streaming or byte-range requests.
Backend / API	Resumable download support	No coverage	Not mentioned.
Backend / API	API authentication & authorisation (token validation)	Partial	Microsoft 365 authentication is described for the client, but server-side token validation on each API call is not specified.
Backend / API	Rate limiting, throttling, abuse prevention	No coverage	Entirely absent. No mention of per-user quotas or bulk-download controls.
Backend / API	Audit logging of file access and downloads	Partial	A 'verified audit trail' for sign-ins is noted, but per-document access and download logging at the API level is not addressed.
File storage & hierarchy	Server-side hierarchical folder structure	Partial	19 categories are defined and flat categorisation is shown. True hierarchical nesting (sub-folders) is not described.
File storage & hierarchy	File metadata handling (name, size, date, type)	Partial	Document names and categories are shown in screenshots; size, modified date, and custom metadata are not addressed.

Proposal Evaluation Report against Mobile Enterprise Security Checklist

File storage & hierarchy	Search capability (title + full-text) with indexing	Partial	Title search is confirmed. Full-text PDF search is mentioned in the viewer section but no server-side indexing approach is described.
File storage & hierarchy	Access control at file/folder level per AD group	No coverage	No per-document or per-category access control is described. All authenticated users appear to see all 346 documents.
File storage & hierarchy	Scalability (pagination, lazy loading)	No coverage	Not addressed. No pagination, lazy loading, or scaling plan for the document library.
PDF processing & viewing	In-app rendering (zoom, navigation, text search, selection)	Full	Integrated PDF viewer with pinch-to-zoom, page navigation, and bookmarks is explicitly stated.
PDF processing & viewing	Streaming PDFs without full download (byte-range)	No coverage	Not addressed. No mention of progressive loading or byte-range requests for large PDFs.
PDF processing & viewing	Offline download and secure local storage (encrypted)	Partial	Offline cache is described but encryption of locally stored PDFs and app-sandbox enforcement are not mentioned.
PDF processing & viewing	Viewer performance for large PDFs	No coverage	No performance considerations or benchmarks for large or complex PDFs are discussed.
User interface & experience	Hierarchical navigation (breadcrumbs, folder drill-down)	Partial	Category navigation is shown in screenshots; breadcrumbs and a true folder hierarchy are not described.
User interface & experience	Multiple view modes, icons, thumbnails	Partial	Category grid is shown. List vs. grid toggle, file type icons, and PDF thumbnails are not described.
User interface & experience	Sort, filter, and real-time search	Partial	Title search within category is shown. Sorting options and advanced filtering are not described.
User interface & experience	Context menu actions (download, share, properties)	Partial	Screenshot blocking and share restriction are mentioned as Phase 2 items. No context menu design is described.
User interface & experience	Offline mode awareness, sync indicators	Partial	Offline cache is described but there is no mention of a UI indicator distinguishing cached from live documents.
User interface & experience	Responsive design (phones/tablets), accessibility, dark mode	No coverage	Text-to-speech is noted for accessibility, but responsive layout for tablets, screen-reader support, and dark mode are not addressed.
Mobile platform & device	Targeted platforms and framework choice	Full	Android primary (Flutter 3), iOS port noted as available, web build also possible from same codebase.
Mobile platform & device	Secure local storage (Keychain/Keystore)	No coverage	Not addressed. The document states credentials are not stored but does not specify how tokens

Proposal Evaluation Report against Mobile Enterprise Security Checklist

	for tokens		are stored after login.
Mobile platform & device	Background download and OS download manager integration	No coverage	Not addressed.
Mobile platform & device	App lifecycle (suspend/resume) and state restoration	No coverage	Not addressed.
Security	End-to-end HTTPS and certificate pinning	Partial	MSAL implies HTTPS; TLS version and certificate pinning are not explicitly specified.
Security	Server-side permission enforcement on every request	No coverage	Never stated. All access control references are client-side (screenshot blocking, share restriction, watermarking).
Security	Protection against path traversal, injection, XSS	No coverage	Not addressed. No mention of input validation or secure coding practices.
Security	Secure data at rest (encrypted local DB, encrypted files)	No coverage	Not addressed. Locally cached documents are not described as encrypted.
Security	Privacy compliance and data minimisation	No coverage	Not addressed. No GDPR/data protection statement despite personal device deployment.
Offline & caching	Caching of directory structures for offline browsing	Partial	Offline document cache is mentioned but directory/category caching is not explicitly described.
Offline & caching	Clear offline status and cached vs. live data indication	No coverage	Not addressed in the UI description.
Offline & caching	Conflict resolution when server file is updated after download	No coverage	The proposal mentions central updates reflecting on 'next refresh' but does not address staleness, TTL, or forced refresh for cached copies.
Performance & scalability	API pagination, thumbnail caching, CDN strategy	No coverage	Not addressed.
Performance & scalability	Server-side caching of AD lookups and directory listings	No coverage	Not addressed.
Performance & scalability	Load testing and benchmarks for concurrent users	No coverage	Not addressed.
Administration, monitoring &	Configuration management for AD	Partial	SharePoint as document store is mentioned; connection configuration and environment

Proposal Evaluation Report against Mobile Enterprise Security Checklist

DevOps	connection and environments		(dev/staging/prod) management are not described.
Administration, monitoring & DevOps	Logging, monitoring, and crash reporting	No coverage	Not addressed for either the app or the backend.
Administration, monitoring & DevOps	CI/CD pipeline, automated testing, staged rollout	Partial	A phased rollout plan is described but CI/CD, automated test suites, and MDM distribution mechanics are not specified.
Administration, monitoring & DevOps	API versioning strategy	No coverage	Not addressed.
Legal & licensing	Third-party library licences (PDF viewer, Flutter packages)	No coverage	No third-party library or licence inventory is provided.
Legal & licensing	Terms of service, privacy policy, EULA	No coverage	Not addressed. Particularly notable for a law-enforcement app deployed on personal devices.

Proposal Evaluation Report against Mobile Enterprise Security Checklist

Summary

Strengths

1. Authentication model is well-considered. Leveraging Microsoft 365 / MSAL / OAuth 2.0 is sound. Domain restriction, automatic deprovisioning, and MFA via Conditional Access are all named.
2. Rollout is staged and realistic. Four-week pilot → hardening → Force-wide is a sensible phased approach with explicit scope per phase.
3. Core UX features are identified. Offline cache, integrated PDF viewer, text-to-speech, full-text search, and category navigation are all specified.
4. Zero-cost pilot is a strong pitch. Reusing existing M365 infrastructure and requesting no budget for Phase 1 reduces adoption friction significantly.

Critical missing pieces

1. No backend / API specification. The document says nothing about REST endpoints, streaming PDFs, byte-range support, rate limiting, or audit logging at the API layer.
2. No AD group → file/folder access control mapping. There is no description of how different officers (by rank, division, role) see different documents. Access control is entirely absent at the data layer.
3. No secure local storage design. Downloaded files are cached on personal devices with no mention of encryption, app sandbox enforcement, or Keystore/Keychain usage.
4. No server-side enforcement. The document mentions client-side controls (screenshot blocking, watermarking) but never states that the backend re-validates every request regardless of client state.
5. No scalability, performance, or DevOps plan. No mention of CI/CD, load testing, API versioning, crash monitoring, or CDN strategy.
6. No legal or licensing coverage. Flutter and third-party libraries have licenses; there is no privacy policy, EULA, or data-minimisation statement for a law-enforcement deployment.

Proposal Evaluation Report against Mobile Enterprise Security Checklist

Recommendation

Priority 1 — Critical (block pilot approval)

1. Define the access control model end-to-end. Specify which AD security groups map to which document categories. Document how the backend enforces this on every API call — not just at login. Include a group-to-document matrix in an appendix.
2. Add a backend API specification. At minimum: list all REST endpoints (list categories, list documents, get document stream, search), define authentication header requirements, specify byte-range/streaming support for PDFs, and describe the audit log schema (who accessed what and when).
3. Specify secure local storage. State explicitly that tokens are stored in Android Keystore (not SharedPreferences), that cached PDFs are stored in encrypted app-private storage, and that files are wiped on logout or remote wipe via Intune.
4. Clarify server-side permission enforcement. Add a sentence confirming that every document-fetch request is authorised server-side against the caller's AD group membership — the backend never trusts the client to self-report permissions.

Priority 2 — High (required before Force-wide rollout)

5. Add a DevOps and monitoring section. Describe the CI/CD pipeline (build, test, sign, distribute via MDM), crash-reporting tooling (e.g. Firebase Crashlytics), API versioning strategy, and who owns each component in production.
6. Add rate limiting and abuse prevention. The document must specify that the API enforces per-user request throttling and that bulk download attempts are flagged. This is especially important given that the document library contains sensitive operational procedures.
7. Define offline conflict resolution. When a policy is updated server-side, what happens to a cached copy on a device that has been offline for days? The proposal must specify a TTL, a staleness indicator in the UI, and a forced refresh policy.
8. Expand the security section on HTTPS and certificate pinning. Confirm TLS 1.2+ minimum, and state whether certificate pinning is in scope to prevent MITM attacks on officer personal devices that may use untrusted root CAs.

Priority 3 — Medium (strengthens the document)

9. Address iOS. The proposal mentions iOS as available "on request." If any officer population uses iOS, the security model (Keychain, app sandbox, MDM profile) must be documented. Treating it as an afterthought creates a two-tier security posture.

Proposal Evaluation Report against Mobile Enterprise Security Checklist

10. Add a legal and licensing appendix. List all third-party Flutter packages and their licences. Include a short data-minimisation statement (what personal data is collected, where it is stored, and the retention period). Even a brief privacy notice is prudent for a law-enforcement tool on personal devices.
11. Specify full-text search architecture. The proposal mentions title search; full-text search inside PDFs is listed as a feature in the viewer but the backend indexing approach (server-side index vs. client-side) is unspecified. Clarify whether search is indexed server-side and whether results from restricted documents are filtered before reaching the client.
12. Add scalability and pagination detail. 346 documents across 19 categories is manageable today, but specify pagination or lazy loading for category lists, and describe how the architecture scales if the library grows to 3,000+ documents over time.